Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 4. Programas, procesos y políticas de seguridad de la información

Índice

Esquema

Ideas clave

4.1. Introducción y objetivos

4.2. Programas de gestión de la seguridad

4.3. La gestión de riesgos

4.4. Diseño de políticas de seguridad

A fondo

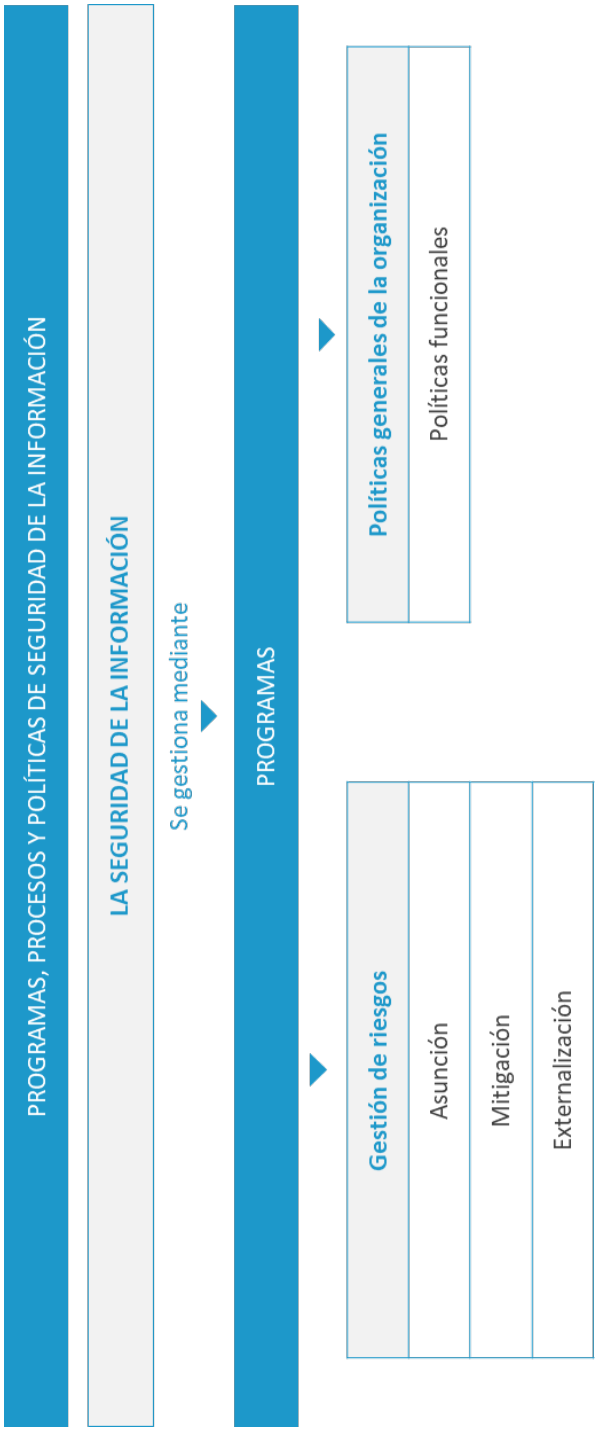
Guía NIST de gestión de riesgos de seguridad de la información

OWASP Hacking by numbers

The University of Manchester IT security policies

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

4.1. Introducción y objetivos

Este tema aborda dos elementos clave en la gestión de la seguridad de la información:

- Gestión de riesgos.
- Políticas.

La gestión de riesgos es una actividad central que se debe contextualizar en las opciones de mitigación del riesgo, con diferentes modelos económicos. Aquí se trata de comprender y saber utilizar la terminología. Es necesario entender bien la diferencia entre asumir, mitigar y externalizar el riesgo y sus consecuencias económicas. Por otro lado, es importante comprender que los controles, como los que se describen en las normas ISO, son el resultado de la gestión del riesgo.

Respecto de las políticas, se describen de manera general y se estudiarán mediante ejemplos para diferentes áreas.

© Universidad Internacional de La Rioja (UNIR)

4.2. Programas de gestión de la seguridad

Como ya sabemos, el **objetivo** de la gestión de la seguridad es garantizar la **confidencialidad, integridad y disponibilidad de los recursos** de información de la organización.

El programa de gestión de la seguridad es un conjunto de actividades planificadas dentro de una organización para garantizar la disponibilidad, confidencialidad e integridad de los recursos de información.

Los programas deben ser **comunicados de forma entendible** a todos los empleados.

Un programa no es una acción concreta, sino un área de gestión orientada a la mejora continua. La importancia de la seguridad de la información ha dado lugar a la profesionalización, materializada en el rol del Responsable de Seguridad de Información (RSI), CISO (Chief Information Security Officer) o denominación equivalente.

La **gestión de la seguridad** se materializa en **políticas, estándares, líneas base y procedimientos.**

- **Políticas:** establecen las directrices generales.
- **Estándares:** establecen las herramientas requeridas.
- **Líneas base:** establecen los parámetros que se utilizarán.
- **Procedimientos:** establecen las guías paso a paso que se deben realizar diariamente.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Es importante resaltar la **importancia de los programas de concienciación** (o educación) de los empleados, necesarios para hacer efectiva la implementación de políticas, estándares y procedimientos.

En cualquier caso, los programas de gestión de la seguridad comienzan por un proceso fundamental, la **gestión de riesgos,** que establece los objetivos de la gestión analizando las amenazas y su potencial impacto.

Posteriormente, esos riesgos analizados serán **el criterio para implementar diferentes tipos de controles.**

© Universidad Internacional de La Rioja (UNIR)

4.3. La gestión de riesgos

Un riesgo es esencialmente la posibilidad de ocurrencia de un evento no deseado, de consecuencias negativas, en nuestro contexto, sobre la seguridad de los recursos de información. Los riesgos deben ser estudiados y analizados, para poder tomar decisiones sobre los mismos. Las decisiones pueden ser básicamente tres:

- Asumir el riesgo tal cual.
- Implementar algún tipo de acción para mitigar el riesgo.
- Externalizar o transferir el coste del riesgo, normalmente mediante la contratación de algún tipo de seguro que actuaría como compensación económica en caso de ocurrencia de este. Otra opción es la de subcontratar ciertos servicios a terceros, que se hacen responsables del riesgo.
- Una cuarta opción sería, lógicamente, la de **evitar el riesgo** dejando de utilizar ciertos recursos o cesando en las actividades asociadas al riesgo, pero lógicamente, esto tiene el coste de oportunidad de no obtener beneficios de la actividad.

La primera opción obviamente solo es viable si la organización es capaz de absorber el coste de la materialización del riesgo. En el caso de seguir la segunda opción, típicamente la organización debe realizar un análisis coste-beneficio, particularmente calcular el riesgo residual.

La gestión de riesgo es el conjunto de procesos para identificar, analizar y evaluar los riesgos y para tomar las decisiones sobre su asunción, mitigación o transferencia.

© Universidad Internacional de La Rioja (UNIR)

Las preguntas sobre el análisis y gestión del riesgo pueden resumirse en las siguientes:

- ¿Qué podría suceder (cuáles son los **eventos** indeseados o amenazas)?
- Si se da el evento, ¿cuán malo puede ser (**impacto** de la amenaza)?
- ¿Con qué frecuencia puede ocurrir (**frecuencia** de amenaza, por ejemplo, anualmente)?
- ¿Cuán seguros estamos de las respuestas a las tres primeras preguntas (**reconocimiento** de nuestra incertidumbre)?

Una vez los riesgos han sido analizados y evaluados, la gestión debe responder a las siguientes preguntas fundamentales:

- ¿Qué se puede hacer (mitigación de riesgos)?
- ¿Cuánto va a costar (por intervalos de tiempo, por ejemplo, anuales)?
- ¿Es rentable (análisis coste/beneficio)?

En lo que sigue profundizamos en los elementos y actividades fundamentales de la gestión de riesgos en la seguridad de la información.

Algunas definiciones previas

La terminología en la gestión de los riesgos, para evitar ambigüedades, debe basarse en estándares como ISO 17799. Algunas definiciones previas importantes son las siguientes:

- **Amenaza** *(threat):* un peligro potencial a un recurso.

© Universidad Internacional de La Rioja (UNIR)

- **Fuente**/agente **de la amenaza** *(threat-source/agent):* algo o alguien que tiene capacidad potencial para materializar la amenaza.
- **Vulnerabilidad:** una debilidad o fallo en un recurso.
- **Exposición:** una oportunidad para que una amenaza cause un daño.

En cuanto a los controles, suelen diferenciarse los siguientes:

- **Mecanismos de mitigación técnicos** (por ejemplo, un *firewall*) **o no-técnicos** (administrativos y físicos): las medidas administrativas incluyen por ejemplo políticas y procedimientos y las físicas por ejemplo alarmas, cerraduras o detectores de fuego.
- **Salvaguardas** *(safeguard):* controles preventivos y proactivos.
- **Contramedidas:** controles correctivos (reactivos).

Procesos en la gestión de riesgos de la información

Existen diferentes modelos y estándares sobre los procesos en la gestión de riesgos. Por ejemplo, el estándar NIST SP-830 agrupa los procesos en tres fases:

- **Evaluación del riesgo** *(risk assessment):* a su vez, se considera dentro de esta fase otras, incluyendo:
- **Cuantitativa** (estimando el valor monetario de la ocurrencia de las amenazas).
- **Cualitativa** (basada en escenarios).
- **Implementación** de controles.
- **Evaluación continua** de los controles.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Independientemente del modelo de procesos o buenas prácticas que se utilice, todos ellos comparten una estimación de la probabilidad de ocurrencia del riesgo y una sugerencia de contramedidas que puedan utilizarse y que se implementarán mediante controles.

Análisis de riesgos cuantitativo

El análisis de riesgos cuantitativo trata de asignar valores cuantitativos (por ejemplo, unidades monetarias) a los diferentes elementos. Para ello, hay que comenzar haciendo una **valoración económica de los recursos.** A partir de esa valoración, se establecen una serie de medidas, la siguiente tabla resume las principales.

Concepto	Formulación
Factor de exposición (*exposure factor*, FE)	Porcentaje de pérdida de valor de un recurso asociado a una amenaza.
Expectativa de pérdida *(single loss expectancy, SLE)*	Valor del recurso multiplicado por FE.
Tasa de ocurrencia anualizada *(annualized rate of occurency, ARO)*	Frecuencia de la ocurrencia de la amenaza anual.
Expectativa de pérdida anual *(annualized loss expectancy, ALO)*	SLE*ARO

Tabla 1. Medidas a tomar ante el análisis de riesgos cuantitativo. Fuente: elaboración propia.

El problema fundamental del análisis es la dificultad de **medir el valor de los recursos.** Este valor puede estimarse de diferentes formas, no excluyentes:

- El **coste inicial y continuo** (para una organización) de la compra, concesión de licencias, el desarrollo y el mantenimiento.
- El **valor del recurso** para el mantenimiento del modelo de negocio o la ventaja

© Universidad Internacional de La Rioja (UNIR)

competitiva, o el valor que aporta al negocio en su funcionamiento.

- El **valor de mercado del recurso,** si se puede evaluar. Por ejemplo, el valor por el que se podría vender un secreto industrial.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La valoración una vez establecida permite el análisis coste-beneficio, dado que las medidas de mitigación (o el coste de externalización) estimado puede compararse con estas valoraciones, sobre la base de estimaciones anualizadas.

© Universidad Internacional de La Rioja (UNIR)

4.4. Diseño de políticas de seguridad

Las políticas tienen muchas utilidades, por ejemplo, pueden ser un salvavidas durante un desastre o podrían ser un requisito de una función reguladora. La política también puede proporcionar protección contra la responsabilidad debida a un trabajador o definir acciones para el control de los secretos comerciales.

Los diferentes tipos de políticas

El término «política» es uno de esos términos que pueden significar varias cosas en seguridad de la información. Por ejemplo, existen políticas de seguridad en servidores, que se refieren al control de acceso y la información de enrutamiento. Los estándares, procedimientos y directrices también se conocen como políticas en el sentido más amplio de la seguridad.

Aquí hacemos referencias a las **políticas como controles administrativos de carácter temático,** a veces denominadas **políticas funcionales.** Por ello adoptamos la siguiente definición de política. Estas políticas detallan las políticas generales de la organización.

Las políticas y su importancia

La política de seguridad de la información es un plan de alto nivel que describe los objetivos de los procedimientos.

© Universidad Internacional de La Rioja (UNIR)

Por lo tanto, las políticas no son directrices o estándares, ni tampoco procedimientos. Las políticas **describen la seguridad en términos generales y no específicos.** Pueden considerarse las plantillas o requisitos generales que determinan cómo se diseñarán e implementarán los diferentes elementos de la seguridad.

La diferencia entre política e implementación es importante. Por ejemplo, si una política estableciese que el *login* único debe hacerse con un producto concreto de una empresa, cuando el mercado evolucione, puede que otros productos sean mejores. No parece razonable que el objetivo (que es lo que define la política) esté ligado a un producto o tecnología concreta, al menos en la mayoría de los casos. Ahora bien, la política sí que puede indicar la obligatoriedad de que, independientemente de la elección de producto final, se documenten las razones de por qué se ha seleccionado.

El diseño de políticas es importante porque estas **definen los objetivos de la seguridad.** Además, la participación de la dirección en la definición de las políticas proporciona un mensaje claro sobre la implicación y **compromiso de la organización** en sus niveles directivos. Las políticas, salvo excepciones convenientemente documentadas y aprobadas, se aplican a la organización entera, por lo que facilitan tener unos **estándares de seguridad coherentes,** y esto es algo que los clientes pueden apreciar y hace la gestión más sencilla.

Por último, las políticas son útiles para **gestionar los litigios.** Si se amonesta a un empleado por una acción relacionada con la seguridad, y no había política escrita, es complicado justificar esa amonestación.

Desde una perspectiva más pragmática, la ausencia de políticas escritas correctamente simplemente impide la evaluación externa y la auditoría.

© Universidad Internacional de La Rioja (UNIR)

Un ejemplo para comenzar

Terminamos esta sección con un ejemplo de política y un análisis de su forma, tomado de comunidad SANS, sus diferencias con otras herramientas de gestión y sus implicaciones.

El documento está disponible en la dirección web: https://assets.contentstack.io/v3/assets/blt36c2e63521272fdc/blt55091bed60041d8e/636d96f9cbd6b84ecb485eb3/Web_Application_Security_Policy.pdf

---

© Universidad Internacional de La Rioja (UNIR)

En la política anterior podemos apreciar una estructura general que suele darse de manera explícita o implícita:

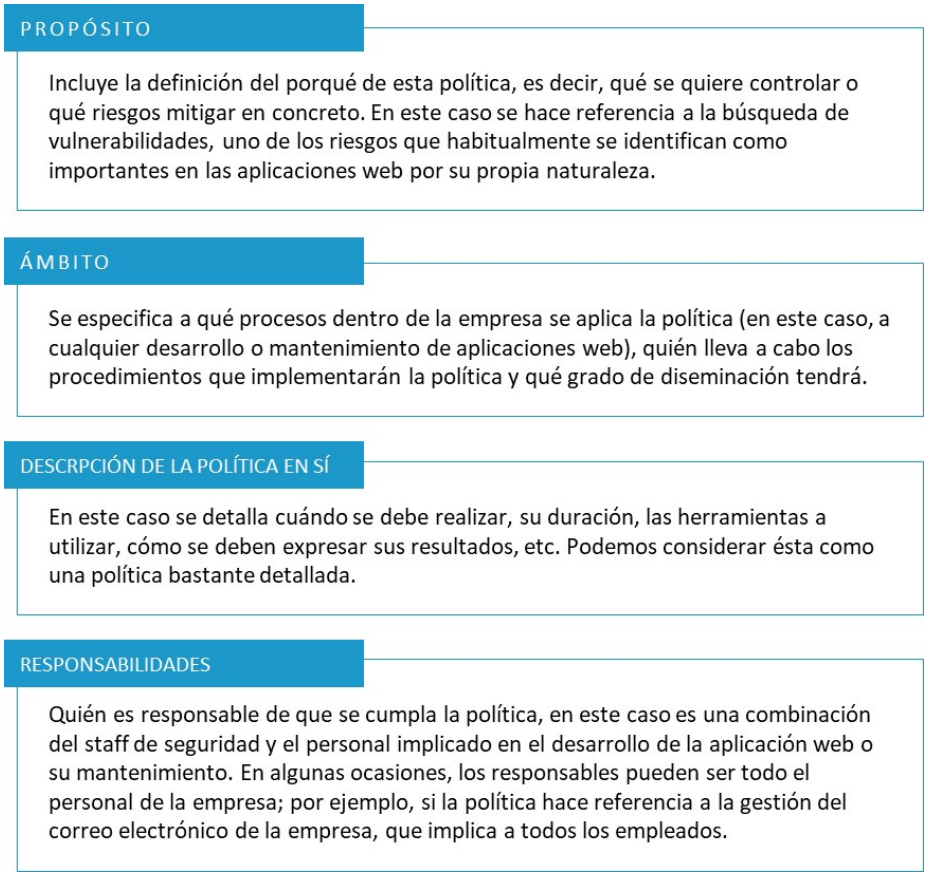


Figura 1. Estructura de la política anterior. Fuente: elaboración propia.

Además de lo anterior, la política incluye una sección de definiciones para hacer precisa la política en sí, así como referencias. Finalmente, dado que las políticas provienen de la implementación de la gestión que es un ciclo de mejora continua, deben tener algún mecanismo de seguimiento de versiones o revisiones.

Estos son los elementos fundamentales que se encuentran de un modo u otro en las políticas. Además de lo anterior, podemos apreciar, en este caso, cómo se reutilizan estándares, concretamente, definiciones de OWASP.

En este caso, esta política llega a detallar herramientas de evaluación concretas.

© Universidad Internacional de La Rioja (UNIR)

Este es un caso especial, dado que en muchas organizaciones esto se especifica en los procedimientos o estándares, dejando la política en sí en un nivel más general. No obstante, es importante resaltar que esta política deberá tener después guías de implementación más detalladas en un procedimiento o varios.

© Universidad Internacional de La Rioja (UNIR)

Guía NIST de gestión de riesgos de seguridad de la información

NIST. (1 de marzo de 2011) *New Publication Fundamentally Changes Federal Information Security Risk Management.* https://www.nist.gov/news-events/news/2011/03/new-publication-fundamentally-changes-federal-information-security-risk

Este documento desarrolla en profundidad un proceso de gestión de riesgos multinivel. Incluye las definiciones, los roles y el proceso de manera exhaustiva. El documento es un buen ejemplo para profundizar en el contexto amplio de la gestión del riesgo.

© Universidad Internacional de La Rioja (UNIR)

OWASP Hacking by numbers

Christiaan008. (1 de septiembre de 2010). *OWASP AppSec 2010: Hacking by Numbers 1/3* [Vídeo]. YouTube. https://www.youtube.com/watch?v=vy2uZyZ_pjs

En esta serie de vídeos del evento OWASP App Research de 2010 se aborda la cuantificación del riesgo en aplicaciones web de acuerdo con el tipo de vulnerabilidades y la probabilidad de ocurrencia.

© Universidad Internacional de La Rioja (UNIR)

The University of Manchester IT security policies

Página de IT Services de la Universidad de Manchester.

Esta web recoge un ejemplo de políticas de seguridad en una organización de tamaño medio.

© Universidad Internacional de La Rioja (UNIR)

1. Indica cuál de las siguientes afirmaciones es correcta:

   A. Los programas de gestión de la seguridad incluyen siempre cursos de capacitación técnica en *hacking* ético.

   B. La gestión del riesgo no incluye el desarrollo de programas de gestión de la seguridad que cubran las diferentes necesidades.

   C. Los programas de gestión de la seguridad se deben evaluar periódicamente para analizar su efectividad.

   D. Ninguna de las anteriores.

2. Indica cuál de las siguientes afirmaciones es correcta:

   A. En la gestión de riesgos de seguridad se debe considerar como prioritarias aquellas vulnerabilidades que puedan tener un impacto mayor en términos económicos.

   B. Todos los riesgos deben llevar a la implantación de controles para su mitigación.

   C. El origen de la amenaza en la gestión de riesgos es cada una de las vulnerabilidades.

   D. Ninguna de las anteriores.

3. Indica cuál de las siguientes afirmaciones es correcta:

   A. Las contramedidas se implementan sin tener en cuenta los riesgos identificados.

   B. La gestión del riesgo se basa en el análisis de los indicadores relativos al número de intrusiones que se han detectado en cada periodo.

   C. La gestión de riesgos se basa siempre en una escala cuantitativa.

   D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

4. Indica cuál de las siguientes afirmaciones es correcta sobre el factor de exposición:

A. Depende del valor del recurso en sí.

B. Depende del impacto de la pérdida en el recurso.

C. Depende de la probabilidad de la amenaza.

D. Ninguna de las anteriores.

5. El cumplimiento de lo definido en un documento categorizado como directriz en una entidad:

A. Es obligatorio en función de quién apruebe el documento.

B. Depende del alcance de aplicación.

C. Es opcional, pero debe ser tenido en cuenta.

D. Ninguna de las anteriores.

6. Indica cuál de las siguientes afirmaciones es correcta sobre la tasa de ocurrencia:

A. Determina el impacto final dado que representa la probabilidad de ocurrencia.

B. En caso de que haya información, puede estimarse mediante frecuencias registradas en el pasado.

C. Siempre se presenta en forma de tasa anual.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

7. Indica cuál de las siguientes afirmaciones es correcta sobre el factor de exposición:

A. El valor de los recursos en el análisis de riesgo se debe hacer a partir de su valor de mercado, y es solo aplicable a los que lo tienen.

B. El valor de los recursos nunca puede estimarse por el lado de los costes de pérdida, en caso de que sean medibles.

C. Algunos recursos tienen un valor estratégico para el mantenimiento del negocio, que son superiores a los costes invertidos en obtenerlos.

D. Ninguna de las anteriores.

8. Indica cuál de las siguientes afirmaciones es correcta con relación en las políticas de seguridad:

A. Indican los objetivos de la seguridad, pero no la manera concreta de obtenerlos.

B. Pueden ser específicas de una aplicación o servicio, como puede ser el uso del correo electrónico.

C. Pueden utilizarse para resolver conflictos de responsabilidad ante incidentes de seguridad.

D. Todas las anteriores.

9. Indica cuál de las siguientes afirmaciones es correcta:

A. Las políticas de seguridad deben definir los responsables de su cumplimiento, en términos de roles.

B. Las políticas de seguridad deben definir el *software* que se debe utilizar en cada ámbito de aplicación.

C. Las políticas de seguridad no deben basarse en estándares externos.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

10. Indica cuál de las siguientes afirmaciones es cierta:

A. Las políticas de seguridad deben ser independientes de las políticas globales corporativas.

B. Las políticas son uno de los elementos que se pueden analizar dentro de una auditoría de seguridad de la información.

C. Las políticas deben describirse para aquellos procesos o tareas dentro de la empresa en la que se tiene contacto con el exterior y, por tanto, hay una posibilidad de intrusión o pérdida de confidencialidad.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)